Instituto Superior
de Engenharia
Politécnico de Coimbra

DEPARTAMENTO DE / DEPARTMENT OF
ENGENHARIA INFORMÁTICA

Implementação e Análise de um sistema de Deteção de Intrusões (IDS) com Suricata

Autor / Author
Guilherme Marques Ferreira
a2024133874@isec.pt
Rodrigo Miguel Coimbras Andrade
a2023128407@isec.pt
Guilherme Ziemer Constante
a2023158982@isec.pt

Nome completo do orientador
Luís Eduardo Faria dos Santos

Nome da Unidade Curricular: Segurança

Data de Entrega: 08/06/2026

INSTITUTO POLITÉCNICO
DE COIMBRA

INSTITUTO SUPERIOR
DE ENGENHARIA
DE COIMBRA

Resumo

A constante evolução das ameaças cibernéticas e o aumento da complexidade dos ataques exigem soluções de segurança robustas e adaptáveis. Este trabalho apresenta a implementação e a análise do Suricata, um Sistema de Deteção de Intrusões (IDS) open-source de alta performance, num ambiente laboratorial simulado. A infraestrutura de rede foi desenhada com recurso ao simulador GNS3, integrando zonas de segurança distintas (LAN, WAN, DMZ), e recorrendo à plataforma Security Onion. O sensor Suricata foi posicionado estrategicamente em modo passivo (Out-of-Band) para monitorizar o tráfego direcionado a serviços críticos alojados na zona desmilitarizada, garantindo visibilidade total sem introduzir latência no tráfego legítimo. Foram desenhados e executados múltiplos cenários de ataque práticos — incluindo varrimentos de rede, ataques de força bruta e de negação de serviço (DoS) — para avaliar as capacidades de Inspeção Profunda de Pacotes (DPI) do sistema. Os resultados obtidos validam a elevada precisão do Suricata na identificação de fluxos anómalos e demonstram a eficácia da aplicação de limiares (*thresholds*) nas regras customizadas para mitigar a exaustão de alertas, consolidando o seu papel como uma ferramenta indispensável na defesa ativa de infraestruturas de rede.

Palavras-chave: Suricata, Sistema de Deteção de Intrusões (IDS), Segurança de Redes, Inspeção Profunda de Pacotes (DPI), Monitorização Passiva.

Conteúdo

Resumo i

Índice ii

Índice de tabelas iv

Índice de figuras v

Lista de abreviaturas vi

1 Introdução 1
1.1 Enquadramento 1
1.2 Conceitos & Palavras-Chave 1
1.3 Estrutura do Documento 2

2 Fundamentação Teórica 3
2.1 Evolução Histórica do Suricata 3
2.2 Funcionamento Interno e Arquitetura do Suricata 4
2.3 Capacidades e Aplicações 6

3 Metodologia e Implementação 7
3.1 Topologia da Rede 7
3.2 Plataforma e Posicionamento do Sensor 9
3.3 Estrutura de Ficheiros e Configuração 9
3.4 Regras de Deteção 11

4 Avaliação Experimental 13
4.1 Metodologia de Teste 13
4.2 Teste 1 – Tráfego Básico (Ping/ICMP) 14
4.3 Teste 2 – Reconhecimento de Rede (Port Scan com Nmap) 14
4.4 Teste 3 – Ataque de Força Bruta SSH 15
4.5 Teste 4 – Negação de Serviço (Floods ICMP e UDP) 16
4.6 Resumo Quantitativo 17

5 Conclusão 19

Referências bibliográficas 21

Anexos 22

Lista de Tabelas

3.1 Segmentação das zonas de segurança 8
3.2 Tabela de encaminhamento e interfaces 9

4.1 Resumo global de alertas gerados pelas regras *custom* 17

Lista de Figuras

3.1 Topologia utilizada durante a simulação no GNS3 8

4.1 Teste 1 Tráfego Básico (Ping/ICMP) 14
4.2 Teste 2 Ataque Reconhecimento de Rede NMAP 15
4.3 Teste 3 Ataque de Força Bruta SSH 16
4.4 Teste 4 Negação de Serviço ICMP Flood 16
4.5 Teste 5 Negação de Serviço UDP Flood 17
4.6 Resumo dos alertas dos ataques 18

Lista de abreviaturas

CPU	*Central Processing Unit*
DMZ	*Demilitarized Zone*
DNS	*Domain Name System*
DoS	*Denial of Service*
DPI	*Deep Packet Inspection*
ELK	*Elastic Stack*
FTP	*File Transfer Protocol*
GNS3	*Graphical Network Simulator-3*
HTTP	*Hypertext Transfer Protocol*
ICMP	*Internet Control Message Protocol*
IDES	*Intrusion Detection Expert System*
IDS	*Intrusion Detection System*
IEEE	*Institute of Electrical and Electronics Engineers*
IP	*Internet Protocol*
IPS	*Intrusion Prevention System*
ISEC	Instituto Superior de Engenharia de Coimbra
JSON	*JavaScript Object Notation*
LAN	*Local Area Network*
NAT	*Network Address Translation*
NSM	*Network Security Monitoring*
OISF	*Open Information Security Foundation*
RFC	*Request for Comments*
SID	*Signature Identifier*
SIEM	*Security Information and Event Management*
SOC	*Security Operations Center*
SPAN	*Switched Port Analyzer*
SSH	*Secure Shell*
TCP	*Transmission Control Protocol*
TLS	*Transport Layer Security*
UDP	*User Datagram Protocol*
VNC	*Virtual Network Computing*
WAN	*Wide Area Network*

1 Introdução

1.1 Enquadramento

A evolução exponencial das ameaças cibernéticas tem demonstrado que as barreiras defensivas convencionais, baseadas meramente em filtragem de pacotes estática, são hoje obsoletas perante ataques complexos. A resiliência das infraestruturas modernas exige uma transição para modelos de **Segurança Ativa**, onde a inspeção profunda de pacotes (DPI) e a análise comportamental em tempo real permitem salvaguardar a confidencialidade e a integridade dos ativos digitais.

O objetivo deste trabalho reside na exploração experimental do Suricata configurado em modo de monitorização passiva (IDS). O objetivo primordial é analisar a capacidade de deteção do sistema perante cenários de intrusão simulados. Para tal, será utilizada uma infraestrutura laboratorial onde a distribuição **Kali Linux** atuará como fonte de ataque, recorrendo a ferramentas de auditoria como o **Nmap** para a execução de *scans* e reconhecimento de vulnerabilidades, entre outras.

Através desta abordagem, pretende-se não só configurar e validar regras de deteção customizadas, mas também dissecar a forma como o Suricata gera alertas detalhados e registos de eventos. Em suma, este projeto visa demonstrar a viabilidade e a eficácia do Suricata na proteção de sistemas, convertendo a análise teórica de segurança num modelo prático de defesa.

1.2 Conceitos & Palavras-Chave

Nesta secção são apresentados os conceitos fundamentais para a compreensão do sistema de proteção de rede a implementar, bem como as tecnologias que sustentam a vertente experimental do projeto.

Intrusion Detection System (IDS) vs. Intrusion Prevention System (IPS): Enquanto o IDS atua como um sensor passivo, gerando visibilidade e alertas sobre potenciais incidentes sem interferir no tráfego, o modo IPS assume uma postura de segurança ativa. Neste último, o Suricata é posicionado *inline*, permitindo-lhe descartar pacotes

em tempo real assim que estes correspondam a uma assinatura de ataque.

Deep Packet Inspection (DPI): Ao contrário da filtragem tradicional, que apenas analisa a camada de rede e de transporte, a tecnologia DPI permite ao Suricata dissecar a camada de aplicação. Isto possibilita a identificação de ameaças camufladas dentro do conteúdo (*payload*) de protocolos como HTTP, DNS ou TLS.

Arquitetura Multithreaded: Diferenciando-se de outras soluções como o Snort (nas suas versões originais), o Suricata utiliza processamento paralelo. Esta capacidade permite distribuir a carga de análise por diversos núcleos do processador, mitigando o risco de perda de pacotes (*packet drop*) em redes com elevado débito.

Motor de Assinaturas e Regras: Corresponde à base de conhecimento do sistema. Cada regra define padrões específicos (como sequências de *bytes* ou comportamentos de protocolo) que, quando detetados, despoletam uma ação predefinida: `alert`, `drop`, `reject` ou `pass`.

Anomalias de Protocolo: Refere-se a comportamentos que violam as normas estabelecidas pelos RFCs. O Suricata consegue detetar ataques *zero-day* ao identificar pacotes malformados que ferramentas de *scanning* ou *fuzzing* utilizam para explorar vulnerabilidades.

1.3 Estrutura do Documento

O presente relatório encontra-se estruturado em cinco capítulos principais. O Capítulo 1 introduz o tema, o enquadramento e os conceitos fundamentais associados à deteção de intrusões. O Capítulo 2 foca-se na fundamentação teórica, descrevendo a evolução histórica do Suricata, a sua arquitetura interna de processamento *multithreaded* e os seus mecanismos de inspeção profunda (DPI). O Capítulo 3 detalha a metodologia de implementação, ilustrando a topologia da rede desenhada no simulador GNS3 e as configurações aplicadas no sistema Security Onion. O Capítulo 4 é dedicado à avaliação experimental, onde são expostos os cenários de ataque simulados e é realizada a análise quantitativa e qualitativa dos alertas gerados. Por fim, o Capítulo 5 sintetiza as principais conclusões retiradas deste trabalho e aponta possíveis direções para desenvolvimentos e testes futuros.

2 Fundamentação Teórica

Os sistemas de deteção e prevenção de intrusões (IDS/IPS) desempenham um papel central na segurança de redes, permitindo uma visibilidade profunda sobre o tráfego e a capacidade de interrupção imediata de fluxos maliciosos. A ferramenta selecionada para o presente projeto é o **Suricata**, um motor de segurança de última geração e *open-source*. Destacando-se pela sua arquitetura de alto desempenho baseada em *multithreading* e pela capacidade de Deep Packet Inspection (DPI), o Suricata oferece maior eficiência na identificação de protocolos complexos e na mitigação de ataques em redes de elevado tráfego.

2.1 Evolução Histórica do Suricata

1. Início (1980–1990)

IDS: History, Concept, and Terminology (Ostec Blog)

Ao contrário do que se possa imaginar, o IDS deixou de ser apenas um conceito teórico ainda nos anos 80. Entre 1984 e 1986 surgiu o **IDES** (*Intrusion Detection Expert System*), um protótipo funcional que introduziu a deteção baseada em desvios estatísticos de comportamento e em regras de violação conhecidas. Até ao final dessa década, o campo já contava com diversos sistemas que combinavam análises estatísticas para identificar atividades intrusivas de forma automatizada, abrindo caminho para os sistemas de monitorização de tráfego que se consolidariam a seguir.

2. Snort (1998)

Snort – Network Intrusion Detection & Prevention System (Página Oficial)

Em 1998, Marty Roesch lançou o **Snort**, que se tornou o motor de deteção e prevenção (IDS/IPS) de código aberto mais popular do mundo. O Snort foi pioneiro ao definir uma linguagem de regras simples e eficaz para identificar ameaças e alertar os

administradores de rede.

Snort 3 Adoption and Architecture Guide (Cisco Secure Firewall Documentation)

O problema: o Snort original foi construído sobre uma arquitetura de *thread* única (*single-thread*). À medida que as velocidades de rede saltaram de 100 Mbps para 1 Gbps e além, começou a enfrentar estrangulamentos: não conseguia processar pacotes com rapidez suficiente num único núcleo de CPU, resultando em perda de pacotes e em pontos cegos na segurança.

3. Suricata (2009)

Introduction to Suricata – What is Suricata? (Documentação Oficial)

Para resolver as limitações de escala das ferramentas existentes, a **OISF** (*Open Information Security Foundation*) desenvolveu o **Suricata**. Nasceu como um motor *open-source* de alta performance, atuando simultaneamente como IDS, IPS e plataforma de monitorização de segurança de rede (NSM). As suas principais melhorias face às ferramentas anteriores são:

- **Multithreading nativo:** o Suricata divide o processamento pelos diferentes núcleos do processador. Em redes de alta velocidade, escala horizontalmente ao distribuir a carga por múltiplos núcleos da CPU, otimizando o rendimento e evitando a perda de dados, aproveitando assim ao máximo o *hardware* moderno.
- **Identificação automática de protocolo:** enquanto os sistemas antigos dependiam muito de portas fixas (ex.: porta 80 para HTTP), o Suricata analisa o conteúdo real do pacote. Se houver tráfego HTTP a correr numa porta não convencional (como a 4444), identifica o protocolo automaticamente e aplica as regras corretas.
- **Extração de ficheiros e *logs*:** para além da simples deteção, o Suricata permite extrair ficheiros suspeitos diretamente do fluxo de tráfego em tempo real para análise posterior, oferecendo uma visibilidade muito mais profunda do que ocorre na rede.

2.2 Funcionamento Interno e Arquitetura do Suricata

Blog Stamus Networks: Funcionamento do Suricata Nagios Library: Análise técnica do Suricata

1. Captura de tráfego e mecanismos de *Zero Copy*. O Suricata captura o tráfego em modo promíscuo através de interfaces como AF_PACKET (no Linux) ou WinP-

cap/Npcap (no Windows). Para garantir o desempenho em redes de alta velocidade (1 Gbps+), utiliza-se o **AF_PACKET v3** com suporte a *Zero Copy*. Este mecanismo permite que o motor aceda aos pacotes diretamente na memória da placa de rede, evitando que o CPU desperdice ciclos a copiar dados entre o *kernel* e o espaço de utilizador.

2. Desmontagem e descodificação (*Decoding*). Após a captura, o Suricata "desmonta"os pacotes para identificar os protocolos. O seu grande diferencial é a gestão em *Multithreading* (*Workers Mode*).

3. Cruzamento de dados (*Matching*) e algoritmos de pesquisa. O motor compara o tráfego com milhares de assinaturas em tempo real. Para evitar latência, não recorre a uma pesquisa linear; em vez disso, utiliza algoritmos avançados como o Hyperscan (da Intel) ou o Aho-Corasick, que permitem procurar múltiplos padrões em simultâneo numa única passagem pelos dados. Este processo é essencial para identificar ameaças conhecidas sem comprometer a largura de banda.

4. Inspeção profunda (DPI) e *Stream Reassembly*. O Suricata é um motor de DPI por excelência. Não analisa apenas pacotes isolados, mas reconstrói fluxos completos através do *Stream Reassembly Engine*, o que lhe permite detetar ameaças que se distribuem por vários pacotes.

5. Tomada de decisão e modos de operação (IDS vs. IPS). A resposta do sistema depende do modo de configuração:

- **Modo IDS (passivo):** o Suricata recebe uma cópia do tráfego (via porta SPAN ou TAP). Se detetar uma ameaça, gera um alerta no ficheiro eve.json e nos restantes registos de segurança, mas não interrompe a ligação.
- **Modo IPS (ativo/*inline*):** o Suricata coloca-se diretamente no caminho do tráfego, utilizando tecnologias como **NFQUEUE** ou **AF_PACKET IPS**. Nestes modos, o motor comunica com a *firewall* do sistema (Netfilter/iptables) para emitir veredictos em milissegundos: **Pass** (permitir), **Drop** (bloquear e descartar o pacote) ou **Reject** (bloquear e enviar um *reset* TCP ao atacante).

2.3 Capacidades e Aplicações

Para além dos mecanismos internos já descritos, o Suricata disponibiliza um conjunto de capacidades que o tornam relevante quer na deteção imediata, quer na investigação posterior:

- **Análise de protocolos:** o motor interpreta diversos protocolos de rede (HTTP, DNS, TLS, etc.), o que permite detetar anomalias comportamentais, como o uso de protocolos em portas não padronizadas ou tentativas de abuso de vulnerabilidades específicas nos métodos de comunicação.
- ***Network Traffic Baselining*:** através da monitorização constante, é possível estabelecer uma "linha de base"do tráfego normal. Esta funcionalidade permite que, futuramente, algoritmos de *machine learning* utilizem os dados do Suricata para identificar desvios estatísticos que possam indicar ataques persistentes ou exfiltração de dados.
- ***Threat Hunting*:** a riqueza e o detalhe dos *logs* gerados (sobretudo em formato JSON) transformam o Suricata numa ferramenta indispensável para a investigação forense. Os profissionais de segurança podem usar estes metadados para correlacionar eventos e procurar proativamente ameaças ocultas que não despoletaram alertas imediatos.

3 Metodologia e Implementação

Este capítulo descreve a infraestrutura laboratorial e os procedimentos necessários para reproduzir o ambiente de monitorização passiva, desde a topologia da rede até à configuração do sensor e à definição das regras de deteção. A rede foi construída no simulador **GNS3 (v2.2.58.1)**, utilizando o **Security Onion 14.04** como plataforma para o Suricata IDS.

3.1 Topologia da Rede

A arquitetura laboratorial adota uma topologia segmentada em três zonas de segurança distintas: **LAN**, **DMZ** e **WAN**. Ao contrário de uma abordagem *inline* restritiva, a configuração adotada baseia-se na monitorização passiva (*Out-of-Band*), recorrendo a um *Hub* para espelhar o tráfego crítico para o sistema de análise, garantindo que a inspeção não introduz latência no fluxo de dados.

A topologia é composta por:

- **Rede Externa (WAN):** simula a Internet ou um segmento de rede não confiável (sub-rede 192.168.123.0/24). Contém a máquina **Kali Linux** (192.168.123.50), otimizada para testes de penetração, que atua como origem das simulações de ataque (ex.: reconhecimento com Nmap e exploração de vulnerabilidades). Esta zona tem ainda ligação ao exterior real através do nó **NAT1**.
- **Infraestrutura de encaminhamento (*Core Routers*):** responsável pela interligação e filtragem entre zonas. O **IOU1** atua como *Edge Router*, fazendo a fronteira e a tradução de endereços (NAT) entre a WAN e a ligação de trânsito (172.16.0.0/30). O **IOU2** atua como *Router* interno, gerindo o encaminhamento entre a ligação de trânsito, a rede interna e a zona de servidores expostos.
- **Rede Local (LAN):** o segmento interno e confiável da infraestrutura (10.0.2.0/24), que simula os postos de trabalho dos utilizadores regulares, representado pelo cliente **ipterm-1** (10.0.2.10).
- **Zona Desmilitarizada (DMZ):** segmento isolado (10.0.1.0/24) destinado a alojar serviços de produção expostos a pedidos externos. É composta por dois servidores alvo, **UbuntuCloudGuest** (10.0.1.10) e **UbuntuCloudGuest-2** (10.0.1.11),

interligados através de comutação de rede (*Switch1*).

- **Nó de segurança e monitorização (Suricata IDS):** o elemento de deteção de intrusões, posicionado estrategicamente na DMZ. Ao estar fisicamente ligado ao **Hub1**, o Suricata (10.0.1.254) recebe cópias de todos os pacotes em circulação nesse segmento (devido à natureza de *broadcasting* do *hub*). Isto permite-lhe atuar de forma invisível e analisar todas as tentativas de comunicação maliciosa dirigidas aos servidores da DMZ, sem constituir um ponto único de falha na rede (*Single Point of Failure*).

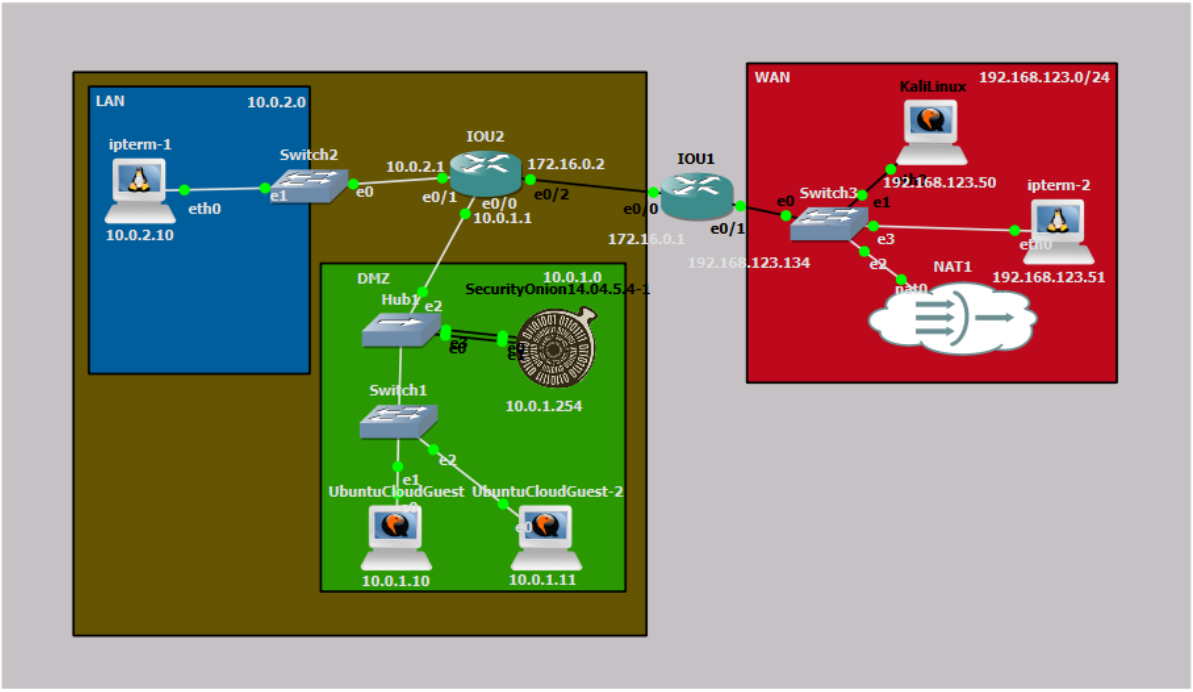


Figura 3.1: Topologia utilizada durante a simulação no GNS3

A segmentação das zonas e o plano de endereçamento e encaminhamento resumem-se nas Tabelas 3.1 e 3.2.

Zona	**Sub-rede**	**Nós**
WAN (Atacante)	192.168.123.0/24	Kali Linux (192.168.123.50)
DMZ (Alvos)	10.0.1.0/24	UbuntuCloudGuest (10.0.1.10), UbuntuCloudGuest-2 (10.0.1.11) Suricata IDS (10.0.1.254)
LAN (Interna)	10.0.2.0/24	ipterm-1 (10.0.2.10)

Tabela 3.1: Segmentação das zonas de segurança

Router	Interface	IP	Função
IOU1	Eth0/0	172.16.0.1/30	Ligação interna para IOU2
IOU1	Eth0/1	192.168.123.134/24	Interface WAN (Switch3/Kali)
IOU2	Eth0/0	10.0.1.1/24	*Gateway* da DMZ
IOU2	Eth0/1	10.0.2.1/24	*Gateway* da LAN
IOU2	Eth0/2	172.16.0.2/30	Ligação para IOU1

Tabela 3.2: Tabela de encaminhamento e interfaces

3.2 Plataforma e Posicionamento do Sensor

O Suricata encontra-se posicionado em modo ***Out-of-Band*** (passivo), ligado ao **Hub1** da DMZ através da interface `eth1` (em modo promíscuo, sem IP atribuído). A interface `eth0` (10.0.1.254) fica reservada à gestão. Devido à natureza do *hub*, que replica todos os *frames* por todas as portas, o Suricata recebe uma cópia integral do tráfego da DMZ sem interferir no fluxo de dados original.

Como o sensor atua de forma passiva, não é necessário configurar o modo de interceção *inline* (`AF_PACKET` com `copy-mode`); o serviço apenas escuta o tráfego numa única interface de captura. Basta, por isso, garantir que a interface física está em modo promíscuo:

```
ip link set eth1 promisc on
```

3.3 Estrutura de Ficheiros e Configuração

O Security Onion utiliza uma arquitetura de ficheiros e pastas própria, que difere significativamente de uma instalação *standalone* (manual) do Suricata. Para a correta implementação e monitorização das regras locais, foi necessário identificar e mapear os caminhos críticos do sistema:

- `/etc/nsm/rules/local.rules`: ficheiro destinado à inserção das regras personalizadas.
- `/etc/nsm/suricata-desktop-eth1/`: diretório com os ficheiros de configuração do sensor associado à interface `eth1`.
- `/nsm/sensor_data/suricata-desktop-eth1/fast.log`: registo de alertas simplificado em texto simples.

- `/nsm/sensor_data/suricata-desktop-eth1/eve.json`: registo detalhado de alertas e metadados em formato JSON.

Alterações ao ficheiro de configuração (suricata.yaml)

Para que o Suricata processasse as regras locais recém-criadas e gerasse os alertas no formato de texto desejado, foi necessário modificar o ficheiro de configuração principal do sensor (`/etc/nsm/suricata-desktop-eth1/suricata.yaml`). Recorrendo ao utilitário `sed`, executaram-se três alterações cirúrgicas: (1) descomentar a linha referente ao `local.rules`, para garantir a sua leitura; (2) ativar a exportação de eventos para o `fast.log`; e (3) corrigir um espaço extra na formatação da linha `downloaded.rules`.

```
# 1. Descomentar o ficheiro local.rules
sudo sed -i 's/^# - local.rules$/- local.rules/' \
    /etc/nsm/suricata-desktop-eth1/suricata.yaml

# 2. Ativar a exportacao para o fast.log
sudo sed -i 's/^      enabled: no$/      enabled: yes/' \
    /etc/nsm/suricata-desktop-eth1/suricata.yaml

# 3. Corrigir a formatacao do downloaded.rules
sudo sed -i 's/^ - downloaded.rules$/- downloaded.rules/' \
    /etc/nsm/suricata-desktop-eth1/suricata.yaml
```

Após as modificações, o bloco correspondente à definição dos caminhos das regras assumiu a seguinte estrutura YAML final:

```
default-rule-path: /etc/nsm/rules
rule-files:
 - local.rules
 - downloaded.rules
```

Aplicação das configurações e monitorização

Para aplicar todas as alterações efetuadas no ficheiro `yaml` e carregar as novas assinaturas em memória, reiniciou-se o processo do sensor associado à interface `eth1`:

```
sudo nsm_sensor_ps-restart --sensor-name=suricata-desktop-eth1
```

Concluída a inicialização, o sistema ficou pronto a analisar o tráfego. Para validar o funcionamento e observar o despoletar de eventos em tempo real durante as simulações de ataque, recorreu-se à monitorização contínua do ficheiro de registo:

```
sudo tail -f /nsm/sensor_data/suricata-desktop-eth1/fast.log
```

3.4 Regras de Deteção

Optou-se pela criação de regras de alerta (`alert`) em detrimento de regras de descarte (`drop`). Esta decisão justifica-se pelo posicionamento do sensor na rede (via *Hub* ou *Port Mirroring*): numa topologia *Out-of-Band* não é possível interromper diretamente o fluxo de dados, servindo o sensor apenas para a monitorização passiva do tráfego.

Estrutura de uma regra (*template*)

As regras do Suricata seguem uma estrutura base dividida em duas partes principais: o **Cabeçalho** (que define as características do tráfego a observar) e as **Opções** (que definem as condições específicas de correspondência e a mensagem do alerta). O formato geral é o seguinte:

```
[Acao] [Protocolo] [Origem] [Direcao] [Destino] (Opcoes da Regra;)
```

1. Cabeçalho da regra (ação e tráfego)

- **Ação:** `alert` (gera um alerta quando o tráfego coincide com a regra).
- **Protocolo:** `icmp` (pode ser TCP, UDP, ICMP, IP, entre outros).
- **Origem:** `any any` (qualquer endereço IP, qualquer porto).
- **Direção:** `->` (fluxo unidirecional, da origem para o destino).
- **Destino:** `10.0.1.0/24 any` (rede da DMZ, qualquer porto).

2. Opções da regra (metadados e filtros)

- `msg`: texto descritivo registado nos *logs* em caso de alerta.
- `itype` e `icode`: filtros específicos do protocolo (ex.: `itype:8` identifica um pacote *Echo Request* de ICMP).
- `sid`: identificador único da assinatura (*Signature ID*). Recomenda-se o uso de valores superiores a `9000000` para regras locais/customizadas.
- `rev`: versão da regra, útil para o controlo de atualizações (começa em `1`).
- `threshold`: limiares aplicados para mitigar a exaustão de alertas (ex.: `count 20, seconds 3` garante que o alerta só dispara se ocorrerem 20 ocorrências num intervalo de 3 segundos).

Regras customizadas implementadas

Com base nesta estrutura, todas as assinaturas desenvolvidas para o laboratório foram concentradas no ficheiro `/etc/nsm/rules/local.rules`, recorrendo a limiares (*thresholds*) para controlar o volume de alertas nos ataques de força bruta e de negação de serviço. As regras dão resposta aos diferentes cenários de ataque simulados no Capítulo 4:

```
# Teste 1: ICMP / Ping basico
alert icmp any any -> 10.0.1.0/24 any (msg:"ICMP Ping Detetado na DMZ";
itype:8; sid:9000001; rev:1;)

# Teste 2: Port Scan (Nmap SYN scan)
alert tcp any any -> 10.0.1.0/24 any (msg:"Port Scan Detetado na DMZ";
flags:S; threshold: type threshold, track by_src, count 20, seconds 3;
sid:9000002; rev:1;)

# Teste 3: Forca Bruta SSH
alert tcp any any -> 10.0.1.0/24 22 (msg:"Forca Bruta SSH na DMZ";
flags:S; threshold: type threshold, track by_src, count 5, seconds 10;
sid:9000003; rev:1;)

# Teste 4: Negacao de Servico - ICMP Flood
alert icmp any any -> 10.0.1.0/24 any (msg:"ICMP Flood Detetado na DMZ";
itype:8; threshold: type threshold, track by_src, count 50, seconds 1;
sid:9000004; rev:1;)

# Teste 4: Negacao de Servico - UDP Flood
alert udp any any -> 10.0.1.0/24 any (msg:"UDP Flood Detetado na DMZ";
threshold: type threshold, track by_src, count 100, seconds 1;
sid:9000005; rev:1;)
```

4 Avaliação Experimental

4.1 Metodologia de Teste

Para validar a eficácia da monitorização e o correto acionamento das regras, foi desenhada uma bateria de quatro testes de complexidade crescente. A partir da máquina atacante (Kali Linux), situada na zona WAN, simularam-se diferentes vetores de ataque contra os servidores alojados na DMZ:

- **Teste 1 – Reconhecimento básico:** testes de conectividade com recurso a tráfego ICMP (`ping`).
- **Teste 2 – Varrimento de portos (*Port Scan*):** mapeamento da superfície de ataque através de varrimentos TCP SYN com a ferramenta Nmap.
- **Teste 3 – Ataque de força bruta:** tentativas sucessivas de autenticação contra o serviço SSH (porto 22).
- **Teste 4 – Negação de serviço (DoS):** inundações volumétricas de tráfego, nomeadamente *ICMP Flood* e *UDP Flood*, com o objetivo de testar o comportamento do sistema sob *stress* e validar a eficácia dos *thresholds*.

O procedimento-padrão de cada cenário baseia-se em dois passos, aqui exemplificados com o varrimento Nmap: (1) na máquina Kali Linux, iniciar a ofensiva contra o servidor alojado na DMZ; e (2) na consola do Security Onion, verificar a geração de alertas em tempo real no ficheiro de registo do sensor.

```
# (1) Na maquina atacante (Kali, WAN)
nmap -sS 10.0.1.10

# (2) Na consola do Security Onion
sudo tail -f /nsm/sensor_data/suricata-desktop-eth1/fast.log
```

Dado o posicionamento *Out-of-Band* do Suricata (modo IDS de escuta passiva), espera-se que **nenhum** dos ataques seja bloqueado: o varrimento Nmap conclui a identificação dos portos, as tentativas de força bruta prosseguem e os pacotes de DoS atingem livremente o servidor de destino. O sucesso da implementação validar-se-á, então, pela capacidade do Suricata em identificar, correlacionar e registar inequivocamente cada uma destas tentativas anómalas nos ficheiros de *log*, comprovando que é possível man-

ter uma postura de deteção rigorosa sem introduzir latência no tráfego legítimo.

4.2 Teste 1 – Tráfego Básico (Ping/ICMP)

Objetivo. Demonstrar a anatomia básica de uma assinatura do Suricata e provar que o motor de análise está a ler o tráfego de rede em tempo real.

Metodologia. Foi criada uma regra personalizada simples (SID 9000001) para monitorizar o protocolo ICMP. Em seguida, executou-se o comando `ping 10.0.1.10` a partir do Kali Linux em direção a um servidor da DMZ.

Resultado. O Suricata intercetou os pacotes ICMP e gravou alertas imediatos no `fast.log`, validando que a regra customizada foi carregada e disparada com sucesso. A execução gerou **14.569 alertas globais**. É de notar que o motor gerou dois alertas por pacote — um pela regra personalizada (SID 9000001) e outro pelas regras comunitárias (*Emerging Threats*, SID 2100366) —, o que demonstra a coexistência ativa de ambas as fontes.

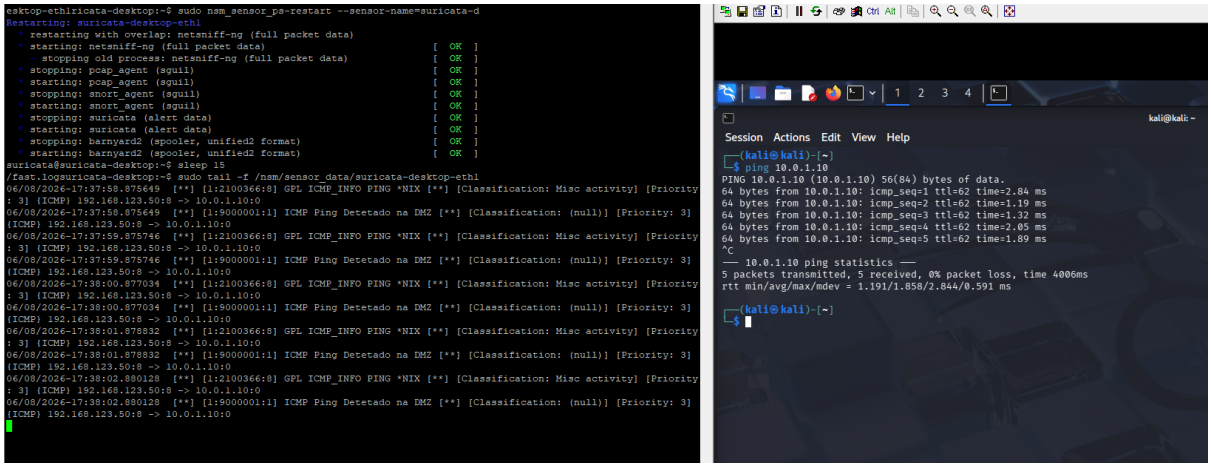


Figura 4.1: Teste 1 Tráfego Básico (Ping/ICMP)

4.3 Teste 2 – Reconhecimento de Rede (Port Scan com Nmap)

Objetivo. Ilustrar a capacidade do Suricata de identificar comportamentos anómalos e varrimentos de portas, que normalmente representam a fase inicial de um ataque

cibernético.

Metodologia. Recorreu-se à ferramenta Nmap para realizar um varrimento TCP SYN agressivo contra a máquina alvo monitorizada (`nmap -sS 10.0.1.10`), gerando um volume rápido de ligações em múltiplas portas.

Resultado. A regra personalizada (SID 9000002) produziu **50 alertas**. Para além disso, o motor identificou proativamente tentativas de ligação a portas críticas (SSH, VNC e bases de dados PostgreSQL, MySQL, Oracle e MS-SQL) através do conjunto `downloaded.rules`, comprovando a profundidade da análise semântica em tempo real. Este teste demonstra que o Suricata não depende apenas de regras manuais para portas específicas, conseguindo interpretar o comportamento ruidoso de um *scanner* de rede.

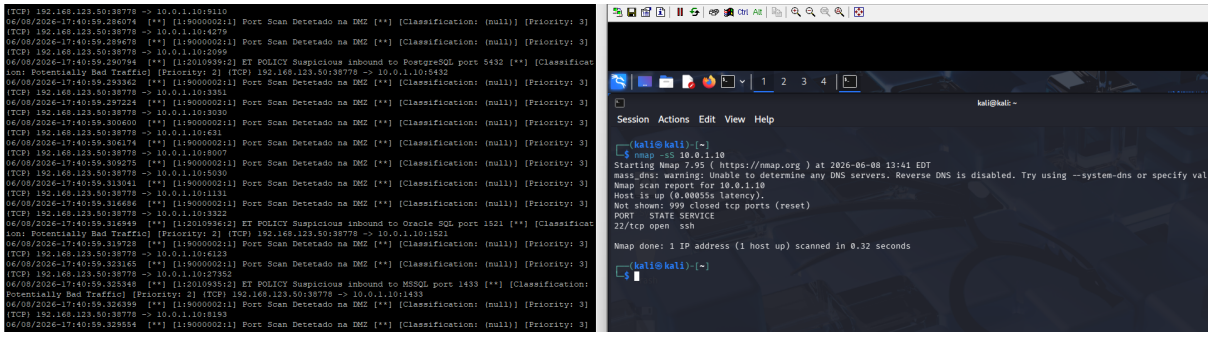


Figura 4.2: Teste 2 Ataque Reconhecimento de Rede NMAP

4.4 Teste 3 – Ataque de Força Bruta SSH

Objetivo. Simular um ataque real de intrusão, evidenciando como o IDS reage a tentativas repetitivas de quebra de credenciais em serviços críticos.

Metodologia. Recorreu-se à ferramenta Hydra, configurada com um dicionário de palavras-passe, direcionando o ataque para o serviço SSH da máquina monitorizada: `hydra -l root -P rockyou.txt ssh://10.0.1.10 -t 4`.

Resultado. A regra de deteção (SID 9000003) gerou exatamente **1 alerta**. Isto comprova o correto funcionamento do *threshold* (limiar de 5 tentativas em 10 segundos), que identifica o padrão comportamental sem necessitar de inspecionar credenciais nem inundar o sistema com alertas duplicados. O registo em formato EVE JSON captura ainda os metadados da ligação, incluindo o IP de origem do atacante.

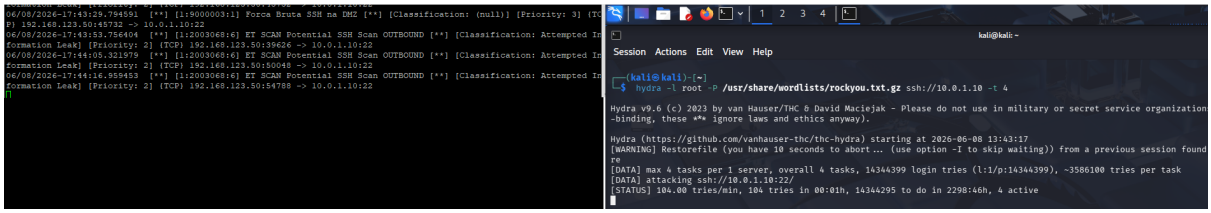


Figura 4.3: Teste 3 Ataque de Força Bruta SSH

4.5 Teste 4 – Negação de Serviço (Floods ICMP e UDP)

Objetivo. Avaliar a capacidade do Suricata em detetar anomalias volumétricas e potenciais ataques de negação de serviço (DoS), baseados na exaustão de largura de banda ou de recursos de rede.

Metodologia. Recorreu-se à ferramenta *hping3* para disparar inundações massivas de pacotes contra a máquina alvo, aplicando regras focadas na contagem de pacotes por segundo (*thresholds*).

Resultado. O sistema reconheceu o pico anormal de tráfego e despoletou alertas contínuos:

- **ICMP Flood** (SID 9000004): ultrapassou rapidamente a métrica de 50 pacotes/segundo, gerando **269 alertas** contínuos.
- **UDP Flood** (SID 9000005): resultou em **492 alertas**, o maior volume registado no laboratório, evidenciando a agressividade da transmissão UDP, sem mecanismos de controlo de fluxo.

Como o Suricata opera em modo passivo, foi possível observar a sinalização da anomalia volumétrica sem que o tráfego de inundação fosse ativamente bloqueado.

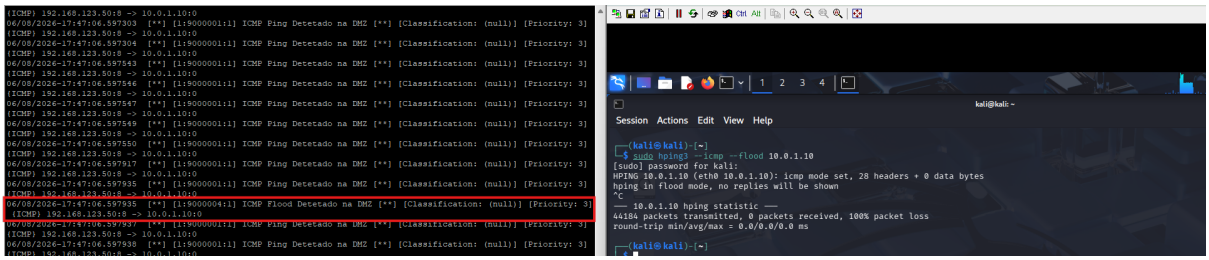


Figura 4.4: Teste 4 Negação de Serviço ICMP Flood

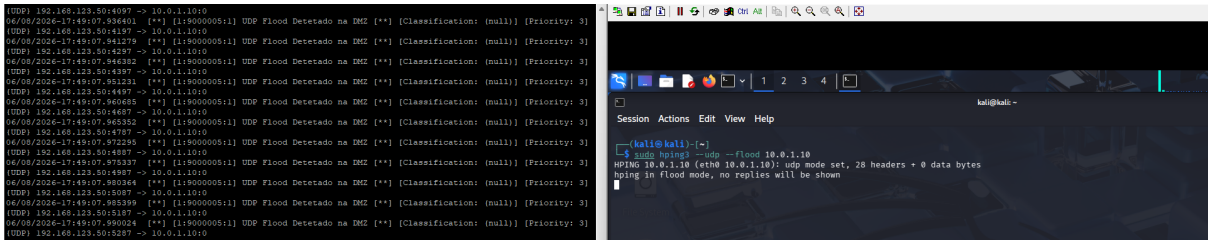


Figura 4.5: Teste 5 Negação de Serviço UDP Flood

4.6 Resumo Quantitativo

A Tabela 4.1 sumaria os alertas despoletados pelas regras personalizadas ao longo dos testes.

Teste	Alvo	SID	Alertas Gerados
1 — ICMP Ping	10.0.1.10	9000001	14.569
2 — Port Scan	10.0.1.10	9000002	50
3 — Força Bruta SSH	10.0.1.10:22	9000003	1
4 — ICMP Flood	10.0.1.10	9000004	269
4 — UDP Flood	10.0.1.10	9000005	492
		Total	**15.381**

Tabela 4.1: Resumo global de alertas gerados pelas regras *custom*

A extração avançada de métricas foi facilitada por expressões regulares aplicadas diretamente aos ficheiros de registo, como ilustra o seguinte comando para consolidação de tipos de alerta no `fast.log`:

```
grep -oP '\[\*\*\] \[1:[0-9]+:[0-9]+\] [^\[]+' fast.log | sort | uniq -c | sort -rn
```

```
suricata@suricata-desktop:/nsm/sensor_data/suricata-desktop-eth1$ grep -oP '\[\*
\*\] \[1:[0-9]+:[0-9]+\] [^\[]+' fast.log | sort | uniq -c | sort -rn
  46609 [**] [1:9000001:1] ICMP Ping Detetado na DMZ
   1310 [**] [1:9000005:1] UDP Flood Detetado na DMZ
    889 [**] [1:9000004:1] ICMP Flood Detetado na DMZ
    200 [**] [1:9000002:1] Port Scan Detetado na DMZ
     19 [**] [1:2100366:8] GPL ICMP_INFO PING *NIX
     17 [**] [1:2003068:6] ET SCAN Potential SSH Scan OUTBOUND
      4 [**] [1:2010939:2] ET POLICY Suspicious inbound to PostgreSQL port 5432
      4 [**] [1:2010937:2] ET POLICY Suspicious inbound to mySQL port 3306
      4 [**] [1:2010936:2] ET POLICY Suspicious inbound to Oracle SQL port 1521
      4 [**] [1:2010935:2] ET POLICY Suspicious inbound to MSSQL port 1433
      4 [**] [1:2001219:19] ET SCAN Potential SSH Scan
      3 [**] [1:9000003:1] Forca Bruta SSH na DMZ
      3 [**] [1:2002911:5] ET SCAN Potential VNC Scan 5900-5920
      3 [**] [1:2002910:5] ET SCAN Potential VNC Scan 5800-5820
suricata@suricata-desktop:/nsm/sensor_data/suricata-desktop-eth1$
```

Figura 4.6: Resumo dos alertas dos ataques

5 Conclusão

A proteção de infraestruturas de rede contemporâneas requer ferramentas capazes de aliar um elevado desempenho a uma análise granular do tráfego em tempo real. Este projeto atingiu com sucesso o objetivo de implementar, configurar e avaliar o Suricata enquanto Sistema de Deteção de Intrusões (IDS) num ambiente de rede segmentado e fidedigno.

Comparação teórico-prática (IDS vs. IPS). Por estar posicionado numa arquitetura *Out-of-Band* (ligado via *Hub*), o Suricata operou de forma puramente passiva (IDS). Enquanto um sistema IPS (*inline*) reteria a capacidade de bloquear o tráfego (`drop/reject`), a presente topologia garante visibilidade total sem introduzir latência nem pontos únicos de falha na rede. Foi por esta razão que os ataques e os varrimentos prosseguiram e concluíram na totalidade, sem que a ligação sofresse cortes. A adoção desta topologia provou ser a abordagem mais adequada para cenários onde a continuidade do serviço é prioritária.

Eficácia das regras e dos limiares. Através da bateria de testes — desde tráfego ICMP básico e reconhecimento de rede via *Port Scan* até ataques de força bruta e inundações volumétricas — atestou-se a eficácia do motor de análise semântica e de processamento paralelo do Suricata, que demonstrou elevada acuidade na correlação de anomalias com as assinaturas pré-definidas. Verificou-se ainda que a aplicação de limiares (*thresholds*) é uma estratégia imprescindível num ambiente de produção, pois mitiga eficazmente a fadiga de alertas (*alert fatigue*), um problema comum durante ataques de DoS.

Otimização de eventos (SIEM). Os ataques de *flood* evidenciaram a rápida escalada do volume de *logs*. Num cenário de produção real, o processamento de mais de 15.000 alertas num curto espaço de tempo exigiria a correlação de eventos através de um SIEM. Na *stack* do Security Onion, esta triagem e agregação é tipicamente conduzida através de interfaces visuais como o *Kibana* ou o *Sguil*, garantindo que a equipa de SOC não é sobrecarregada com ruído informacional.

Trabalho Futuro

Apesar dos resultados promissores no modo de monitorização passiva (IDS), a evolução natural deste trabalho passará pela transição do Suricata para um modelo de Prevenção de Intrusões ativo (IPS). Sugere-se, em projetos futuros, a implementação do sistema em modo *inline*, utilizando mecanismos de encaminhamento ao nível do *kernel* (como o NFQUEUE), de forma a avaliar a eficácia do Suricata no bloqueio ativo (ações de `drop` e `reject`) de fluxos maliciosos sob condições de tráfego intenso.

Adicionalmente, a integração nativa dos registos em formato EVE JSON com plataformas avançadas de correlação de eventos (SIEM) — como a Elastic Stack (ELK) ou o Splunk — representaria um acréscimo significativo, permitindo a aplicação de algoritmos de *Machine Learning* para a deteção de ameaças *zero-day* e a criação de painéis visuais (*dashboards*) para equipas de *Security Operations Center* (SOC).

Bibliografia

[1] F. Coutinho, P. Silva, and R. Rodrigues, "Como escrever um bom relatório em latex," ISEC/IPC, Coimbra, Tech. Rep., Nov. 2022.

[2] OISF, "Suricata official documentation," https://docs.suricata.io/, 2026.

[3] ——, "Suricata rules syntax," https://docs.suricata.io/en/latest/rules/intro.html, 2026.

[4] S. O. Solutions, "Security Onion documentation," https://docs.securityonion.net/, 2026.

[5] Proofpoint, "Emerging threats rules," https://rules.emergingthreats.net/, 2026.

[6] S. Networks, "How does Suricata work?" https://www.stamus-networks.com/blog/how-does-suricata-work, 2024.

[7] OSTEC, "IDS: History, concept, and terminology," https://ostec.blog/en/perimeter/ids-history-concept-terminology/, 2023.

[8] Snort, "Snort - Network Intrusion Prevention & Detection System," https://www.snort.org/, 2024.

[9] Cisco, "Snort 3 adoption guide," https://secure.cisco.com/secure-firewall/docs/snort-3-adoption, 2024.

[10] OISF, "What is Suricata?" https://docs.suricata.io/en/latest/what-is-suricata.html, 2024.

[11] ——, "Suricata features," https://suricata.io/features/, 2024.

[12] N. Library, "Suricata deep dive: What, why, and how," https://library.nagios.com/techtips/suricata-deep-dive-what-why-how/, 2023.

Anexos

Anexo A - Topologia Implementada Completa

A topologia montada pelo nosso grupo totalmente funcional e configurada no âmbito deste projeto encontra-se disponível para consulta através do seguinte diretório partilhado no Google Drive:

`https://drive.google.com/drive/folders/1F8bKU3PEGs_kEHILi_TY3T7RDoFxp6W0?usp=sharing`



Instituto Superior de Engenharia
Politécnico de Coimbra